ANNEXE B

PLAN PROJET POUR LA CERTIFICATION DU SYSTÈME DE MANAGEMENT DE LA SÉCURITÉ DE L'INFORMATION (SMSI)

Version : 1.0

Classification : Interne

Statut : Approuvée

Auteur : Consultant Cybersécurité

Client : BioMarket

Approbateur : Direction Générale — Antoine Verger

Historique des versions

Version	Date	Auteur	Description
0.1	01/06/2026	Consultant cybersécurité	Création du document
0.9	15/06/2026	DSI	Relecture technique
1.0	30/06/2026	Direction Générale	Validation finale

Diffusion

Destinataire	Diffusion
Direction Générale	Oui
DSI	Oui
Responsable RH	Oui
Consultant cybersécurité	Oui
Équipe informatique	Oui
Iron4Software (extrait)	Selon les besoins

Confidentialité

Ce document est destiné exclusivement aux personnes autorisées par BioMarket. Il contient des informations relatives à l'organisation du projet de certification du SMSI et ne peut être diffusé sans l'accord de la Direction.

Table des matières

1. Objet du document 3
2. Contexte 3
3. Objectifs du projet 3
4. Références documentaires 4
5. Périmètre de certification 5
6. Processus critiques 7
7. Interfaces avec les éléments externes 9
8. Éléments exclus du périmètre 9
9. Analyse des enjeux internes et externes 10
10. Exigences juridiques et réglementaires 13
11. Contraintes et hypothèses 15
12. Critères de succès 15
13. Gouvernance du projet 16
14. Planning du projet 19
15. Budget prévisionnel 21
16. Gestion des risques du projet 23
17. Livrables du projet 24
18. Validation du document 24
19. Conclusion 25

1. Objet du document

Le présent document constitue le **plan projet de certification du Système de Management de la Sécurité de l'Information (SMSI)** de BioMarket.

Il définit l'organisation du projet, son périmètre, les objectifs poursuivis, les responsabilités des différents acteurs ainsi que les moyens humains, techniques et financiers nécessaires à sa réalisation.

Ce document a pour finalité de fournir un cadre de pilotage unique permettant de préparer BioMarket à une démarche de certification conforme aux exigences de la norme **ISO/IEC 27001**.

---

2. Contexte

BioMarket est une enseigne spécialisée dans la distribution de produits biologiques disposant d'un siège social à Tourcoing et de plus de cinquante points de vente répartis entre le Nord de la France et la Belgique. L'entreprise souhaite accompagner son développement par la création d'une plateforme e-commerce développée par le prestataire Iron4Software sur une plateforme PaaS. Cette transformation numérique accroît les enjeux liés à la protection des informations et conduit BioMarket à structurer sa démarche de sécurité au travers d'un SMSI.

L'analyse de l'existant met en évidence plusieurs mesures déjà déployées (pare-feu, VPN SSL, MFA pour les comptes à privilèges, segmentation réseau) ainsi que des axes d'amélioration concernant la gouvernance, la revue des habilitations, la formalisation des procédures et la conformité au RGPD.

Le présent plan projet constitue la feuille de route qui permettra de préparer l'entreprise à la certification du SMSI tout en accompagnant le développement sécurisé de la plateforme e-commerce.

---

3. Objectifs du projet

Le projet poursuit les objectifs suivants :

- mettre en place un SMSI conforme aux principes de l'ISO/IEC 27001 ;
- protéger les informations stratégiques et les données personnelles traitées par BioMarket ;
- accompagner le développement sécurisé de la plateforme e-commerce ;
- améliorer la gouvernance de la sécurité de l'information ;
- renforcer la conformité réglementaire, notamment vis-à-vis du RGPD ;
- structurer les processus de sécurité et favoriser une démarche d'amélioration continue ;
- préparer l'entreprise à un futur audit de certification.

4. Références documentaires

Le présent plan projet s'appuie sur les référentiels, normes et documents suivants.

Référence	**Description**
ISO/IEC 27001:2022	Système de management de la sécurité de l'information – Exigences
ISO/IEC 27002:2022	Mesures de sécurité de l'information
Règlement (UE) 2016/679 (RGPD)	Protection des données personnelles
Guides ANSSI	Bonnes pratiques de cybersécurité
CERT-FR	Veille sur les vulnérabilités et les menaces
Documentation interne BioMarket	Architecture, organisation, politiques existantes

---

5. Périmètre de certification

5.1 Définition du périmètre

Le périmètre de certification retenu couvre l'ensemble des activités, des processus et des actifs participant directement au fonctionnement du système d'information de BioMarket.

Il comprend les infrastructures exploitées par BioMarket ainsi que les processus métiers manipulant des informations sensibles. Les interactions avec les prestataires externes sont intégrées au périmètre lorsqu'elles peuvent avoir un impact sur la sécurité des informations.

La plateforme e-commerce développée par Iron4Software est incluse dans le périmètre du SMSI. Bien qu'elle soit actuellement en cours de développement et hébergée dans un environnement PaaS, elle constitue un composant essentiel du système d'information de BioMarket. Le périmètre prend notamment en compte les données traitées, les exigences de sécurité applicables, les échanges avec Iron4Software ainsi que les interfaces avec les autres composants du SI.

5.2 Sites concernés

Le périmètre de certification couvre les sites suivants :

Site	**Description**
Siège de Tourcoing	Hébergement des principaux services d'infrastructure et administration du SI
Magasins BioMarket	Plus de 50 points de vente connectés au système d'information centralisé
Télétravail	Accès distants des collaborateurs via VPN SSL
Prestataire Iron4Software	Échanges liés au développement de la plateforme e-commerce

---

5.3 Actifs concernés

Actifs matériels

- Serveurs physiques et virtuels
- Postes de travail
- Équipements réseau (switches, routeurs)
- Pare-feu Fortinet
- Équipements VPN
- Baies de stockage

Actifs logiciels

- Windows Server 2022
- Active Directory
- DNS
- DHCP
- PostgreSQL
- Outils d'administration
- Services Cloud

Actifs informationnels

- Données clients
- Données fournisseurs
- Données RH
- Données comptables
- Documents internes
- Sauvegardes
- Journaux d'événements (logs)

Actifs humains

- Direction générale
- DSI
- Équipe informatique
- Collaborateurs
- Responsables de magasins
- Prestataire Iron4Software

---

6. Processus critiques

L'analyse du fonctionnement de BioMarket permet d'identifier les processus critiques qui devront être protégés dans le cadre du SMSI.

6.1 Gestion des identités

Ce processus couvre la création, la modification et la suppression des comptes utilisateurs ainsi que l'attribution des droits d'accès dans l'Active Directory.

Une gestion rigoureuse des identités est indispensable afin de garantir que seules les personnes autorisées puissent accéder aux ressources du système d'information.

6.2 Gestion des accès

Ce processus assure le contrôle des habilitations accordées aux utilisateurs, aux administrateurs et aux prestataires.

Il comprend notamment :

- les accès aux serveurs ;
- les accès VPN ;
- les comptes à privilèges ;
- les accès aux ressources Cloud.

6.3 Gestion des données clients

Les données personnelles des clients constituent un actif stratégique de BioMarket.

Le processus couvre :

- la collecte ;
- le stockage ;
- la consultation ;
- la modification ;
- la suppression.

Une attention particulière devra être portée à leur confidentialité et à leur conformité au RGPD.

6.4 Gestion documentaire

Ce processus concerne l'ensemble des documents internes de l'entreprise.

Il comprend :

- les documents RH ;

- les documents financiers ;
- les procédures ;
- les contrats ;
- les documents techniques.

6.5 Administration du système d'information

Ce processus couvre :

- l'administration des serveurs ;
- la gestion des sauvegardes ;
- les mises à jour ;
- la supervision ;
- le maintien en conditions de sécurité.

6.6 Développement de la plateforme e-commerce

Bien que la plateforme ne soit pas encore en production, le développement constitue un processus critique.

Les échanges avec Iron4Software devront respecter les exigences de sécurité définies par BioMarket afin de garantir une intégration sécurisée lors de la mise en production.

---

7. Interfaces avec les éléments externes

Le SMSI devra prendre en compte les interactions entre BioMarket et plusieurs acteurs externes.

Interface	Description
Iron4Software	Développement de la plateforme e-commerce
Fournisseur Cloud	Hébergement d'une partie des données
Clients	Accès futur au service e-commerce
Fournisseurs	Échanges commerciaux
Internet	Accès aux services publics

Ces interfaces feront l'objet d'une surveillance particulière dans le cadre de l'analyse des risques.

---

8. Éléments exclus du périmètre

Le projet de certification ne couvre pas les éléments suivants :

Élément	Justification
Infrastructure interne d'Iron4Software	Hors responsabilité de BioMarket
Infrastructure physique du fournisseur Cloud	Gérée par le fournisseur
Réseaux publics Internet	Hors contrôle de BioMarket
Équipements personnels des clients	Non administrés par BioMarket

Toutefois, les risques liés à ces éléments seront évalués lors de l'analyse des risques du SMSI.

---

9. Analyse des enjeux internes et externes

9.1 Objectif

L'identification des enjeux permet de comprendre les facteurs susceptibles d'influencer la réussite du projet de certification du SMSI.

Cette analyse sert à orienter les décisions de gouvernance, à définir les priorités du projet et à garantir que les mesures de sécurité répondront aux besoins réels de BioMarket.

9.2 Enjeux internes

Les enjeux internes sont directement liés à l'organisation, aux processus et au fonctionnement quotidien de BioMarket.

Développer une plateforme e-commerce sécurisée

Le projet de plateforme e-commerce représente une évolution stratégique pour BioMarket. L'ouverture d'un nouveau canal de vente implique l'exposition de nouveaux services accessibles depuis Internet, augmentant ainsi la surface d'attaque de l'entreprise.

Le SMSI devra garantir que la sécurité est intégrée dès la conception du projet afin de limiter les risques liés à cette transformation numérique.

Protéger les informations sensibles

BioMarket traite quotidiennement des données sensibles :

- données personnelles des clients ;
- informations RH ;
- données financières ;
- contrats fournisseurs ;
- documents internes.

La protection de ces informations constitue un enjeu majeur afin de préserver la confidentialité, l'intégrité et la disponibilité des données.

Structurer les processus de sécurité

L'analyse de l'existant montre que plusieurs mesures de sécurité sont déjà déployées (pare-feu, VPN SSL, MFA, segmentation réseau), mais certaines procédures restent peu formalisées.

Le projet de certification vise donc à :

- documenter les processus ;
- formaliser les procédures ;

- harmoniser les pratiques de sécurité.

Renforcer la gouvernance

Aujourd'hui, plusieurs pratiques reposent essentiellement sur l'expérience des équipes.

Le SMSI devra instaurer :

- une gouvernance documentée ;
- une répartition claire des responsabilités ;
- un suivi régulier des actions ;
- une amélioration continue.

9.3 Enjeux externes

Les enjeux externes correspondent aux contraintes imposées par l'environnement de BioMarket.

Évolution du marché

Les habitudes d'achat évoluent rapidement vers le commerce en ligne.

La mise en œuvre de la plateforme e-commerce constitue un enjeu de compétitivité afin de maintenir la position de BioMarket face aux autres enseignes spécialisées.

Protection des données des clients

Les clients accordent une importance croissante à la protection de leurs données personnelles.

Une violation de données pourrait entraîner :

- une perte de confiance ;
- une atteinte à l'image de BioMarket ;
- des conséquences financières ;
- des sanctions réglementaires.

Conformité réglementaire

Le projet devra respecter plusieurs exigences légales, notamment :

- le RGPD ;
- les obligations contractuelles ;
- les recommandations de l'ANSSI ;
- les exigences de la norme ISO 27001.

Prestataires

BioMarket s'appuie sur plusieurs partenaires externes.

Le prestataire Iron4Software intervient dans le développement de la plateforme e-commerce et dispose d'accès privilégiés au système d'information.

Le SMSI devra garantir que ces interventions sont encadrées par des exigences de sécurité adaptées.

9.4 Synthèse des enjeux

Enjeux internes	**Enjeux externes**
Développement sécurisé du e-commerce	Évolution du marché
Protection des données sensibles	Attentes des clients
Formalisation des processus	RGPD
Gouvernance du SMSI	Cybermenaces
Continuité des activités	Sécurité des prestataires

---

10. Exigences juridiques et réglementaires

10.1 Objectif

Le projet de certification doit garantir que BioMarket respecte les principales exigences juridiques applicables à son activité.

Ces exigences seront intégrées dans les politiques, procédures et mesures de sécurité du SMSI.

10.2 RGPD

BioMarket traite des données personnelles relatives :

- aux clients ;
- aux salariés ;
- aux fournisseurs.

L'entreprise devra notamment :

- garantir la confidentialité des données ;
- assurer leur intégrité ;
- protéger leur disponibilité ;
- documenter les traitements ;
- gérer les droits des personnes concernées ;
- notifier les violations de données lorsque cela est nécessaire.

10.3 Relations avec les prestataires

Les contrats conclus avec Iron4Software et le fournisseur Cloud devront intégrer des clauses relatives :

- à la confidentialité ;
- à la sécurité des traitements ;
- à la gestion des incidents ;
- aux responsabilités de chaque partie.

10.4 Référentiel ISO/IEC 27001

Le projet s'appuie sur les exigences de la norme ISO/IEC 27001.

Le SMSI devra notamment prévoir :

- une politique de sécurité ;
- une analyse des risques ;
- une amélioration continue ;
- des audits internes ;
- une revue de direction.

10.5 Tableau de conformité

Exigence	**Impact pour BioMarket**
RGPD	Protection des données personnelles
ISO/IEC 27001	Mise en œuvre du SMSI
Contrats fournisseurs	Sécurisation des prestations
Documentation	Formalisation des procédures

---

11. Contraintes et hypothèses

11.1 Contraintes

Le projet devra tenir compte des contraintes suivantes :

- maintien de l'activité pendant le projet ;
- disponibilité limitée des équipes métiers ;
- coordination avec Iron4Software ;
- évolution progressive de la plateforme e-commerce.

11.2 Hypothèses

Le présent plan projet repose sur les hypothèses suivantes :

- la Direction maintient son engagement tout au long du projet ;
- les ressources nécessaires seront disponibles ;
- les prestataires collaboreront aux actions de sécurité ;
- le périmètre du projet restera stable pendant sa réalisation.

---

12. Critères de succès

Le projet sera considéré comme réussi si les objectifs suivants sont atteints :

- périmètre du SMSI validé ;
- gouvernance opérationnelle mise en place ;
- exigences réglementaires prises en compte ;
- PSSI approuvée par la Direction ;
- analyse des risques réalisée ;
- plan d'actions validé ;
- audit interne satisfaisant ;
- dossier prêt pour l'audit de certification.

13. Gouvernance du projet

13.1 Objectif

La gouvernance du projet a pour objectif de définir les responsabilités, les modalités de pilotage et les circuits de décision nécessaires à la réussite du projet de certification du SMSI.

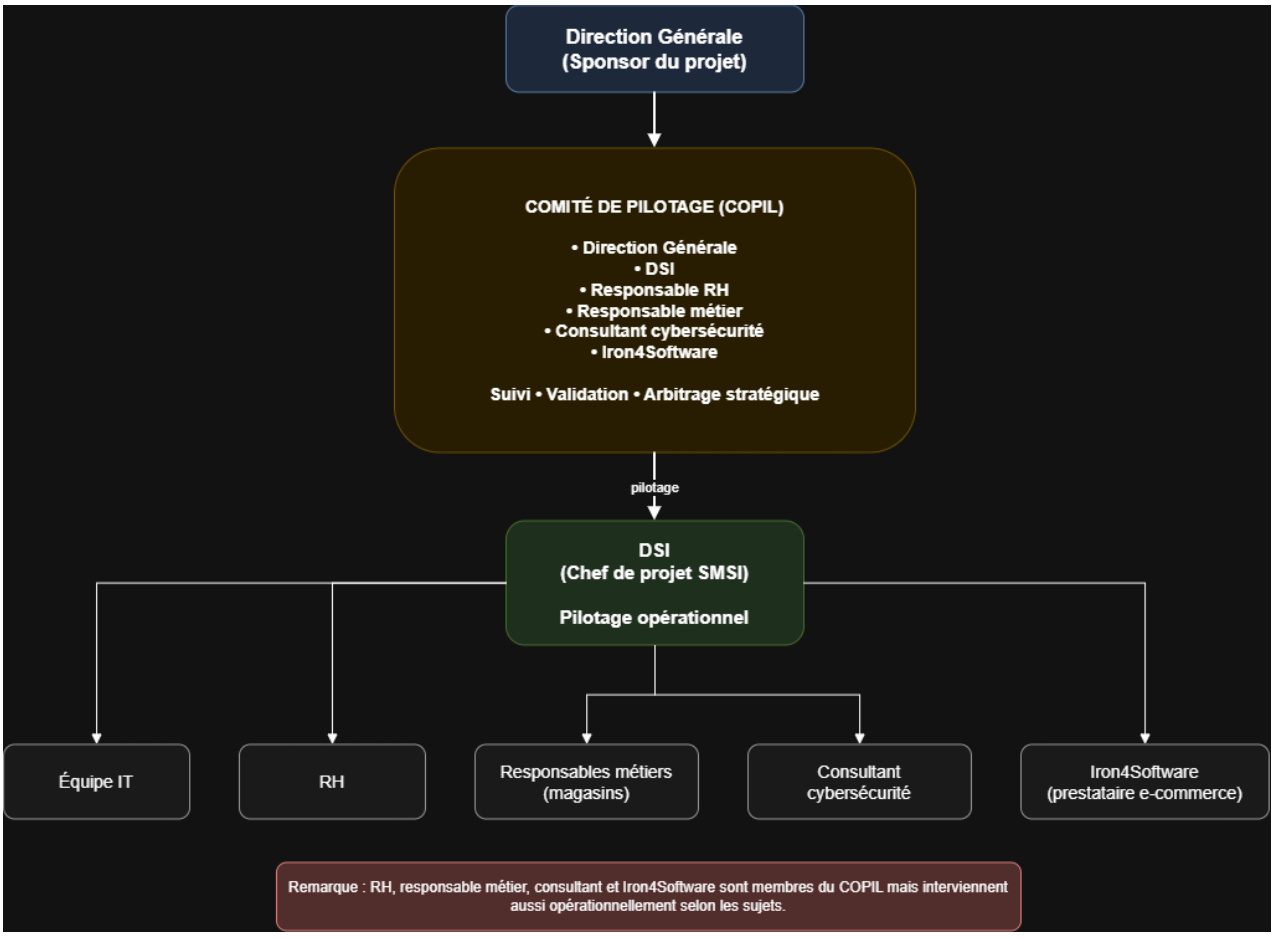
Une gouvernance clairement définie permet d'assurer une coordination efficace entre les différentes parties prenantes et de garantir que les décisions sont prises au niveau approprié.

13.2 Organisation du projet

Le projet est piloté par un **Comité de Pilotage (COPIL)** chargé de suivre l'avancement des travaux, de valider les livrables et d'arbitrer les décisions stratégiques.

La conduite opérationnelle est assurée par la DSI avec l'appui du consultant cybersécurité.

Organisation générale



13.3 Comité de Pilotage

Le Comité de Pilotage est composé des membres suivants :

Fonction	Rôle
Direction Générale	Validation stratégique
DSI	Pilotage opérationnel
DPO	Protection des données personnelles et conformité RGPD
Responsable RH	Gestion des ressources humaines
Consultant cybersécurité	Conseil et coordination
Responsable métier	Expression des besoins
Iron4Software	Participation sur les sujets e-commerce

Le comité se réunit **une fois par mois** ou à chaque jalon majeur du projet.

13.4 Matrice RACI

Activité	Direction	DSI	IT	RH	Consultant	Iron4Software
Définition du périmètre	A	R	C	I	R	I
Analyse des enjeux	I	A	C	C	R	C
Exigences juridiques	I	C	I	C	R	I
PSSI	A	R	C	C	R	I
Analyse des risques	I	A	R	C	R	C
Déploiement	I	A	R	I	C	R
Audit interne	I	A	R	I	R	C
Certification	A	R	C	I	R	I

Légende

- **R** : Responsable de la réalisation
- **A** : Responsable de la validation
- **C** : Consulté
- **I** : Informé

13.5 Communication

Afin d'assurer une bonne coordination, plusieurs réunions seront organisées :

Réunion	**Fréquence**
Comité de Pilotage	Mensuelle
Réunion DSI / Consultant	Hebdomadaire
Réunion technique	Selon les besoins
Comité de clôture	Fin du projet

Chaque réunion donnera lieu à un compte rendu diffusé aux parties concernées.

---

14. Planning du projet

14.1 Calendrier prévisionnel

La durée prévisionnelle du projet est estimée à 9 mois, sous réserve de la disponibilité des ressources et de l'avancement des actions

Phase	Durée
Lancement du projet	2 semaines
Définition du périmètre	2 semaines
Analyse des enjeux	2 semaines
Exigences réglementaires	1 semaine
Gouvernance	1 semaine
Analyse des risques	1 mois
Élaboration de la PSSI	1 mois
PCA	1 mois
Déploiement des actions	2 mois
Audit interne	2 semaines
Préparation certification	2 semaines

14.2 Diagramme de Gantt

Phase	M1	M2	M3	M4	M5	M6	M7	M8	M9
Lancement du projet	■								
Définition du périmètre	■	■							
Analyse des enjeux		■	■						
Exigences réglementaires			■						
Gouvernance			■						
Analyse des risques			■	■	■	■			
Élaboration de la PSSI				■	■	■			
PCA					■	■	■		
Déploiement des actions						■	■	■	■
Audit interne								■	■
Préparation certification								■	■

14.3 Jalons

Jalon	Livrable attendu
J1	Périmètre validé
J2	Analyse des enjeux validée
J3	Exigences réglementaires validées
J4	Gouvernance approuvée
J5	Analyse des risques terminée
J6	PSSI validée
J7	PCA finalisé
J8	Déploiement terminé
J9	Audit interne réalisé
J10	Dossier prêt pour la certification

---

15. Budget prévisionnel

15.1 Estimation des coûts

Poste	Coût estimé (€ HT)
Consultant cybersécurité	35 000 €
Formation des collaborateurs	10 000 €
Préparation audit ISO	15 000 €
Documentation SMSI	10 000 €
Outils de gestion du projet	10 000 €
Mise en œuvre et renforcement des mesures de sécurité	195 000 €
Assistance Iron4Software	20 000 €
Réserve projet	20 000 €
TOTAL	315 000 €

15.2 Répartition budgétaire

Le budget global prévisionnel du projet de préparation à la certification du SMSI est estimé à 315 000 € HT. La majeure partie de l'enveloppe est consacrée à la mise en œuvre des mesures techniques et organisationnelles issues de l'analyse des risques et du plan d'actions de sécurité.

Cette répartition constitue un macro-chiffrage. Les coûts définitifs pourront évoluer selon les solutions retenues, le nombre de licences, les modalités de déploiement, les prestations d'accompagnement et les conditions contractuelles des fournisseurs.

Catégorie	Montant (€ HT)	Part
Ressources humaines	35 000 €	11 %
Mesures techniques	195 000 €	62 %
Audit et certification	15 000 €	5 %
Formation	10 000 €	3 %

Catégorie	Montant (€ HT)	Part
Documentation	10 000 €	3 %
Outils de gestion du projet	10 000 €	3 %
Réserve projet	20 000 €	6 %
Assistance Iron4Software	20 000 €	6 %
TOTAL	315 000 €	100 %

---

16. Gestion des risques du projet

16.1 Principaux risques

Risque	Probabilité	Impact	Niveau	Mesure préventive
Retard du projet	Moyen	Élevé	Important	Suivi hebdomadaire
Disponibilité des équipes	Moyen	Moyen	Modéré	Planification
Retard d'Iron4Software	Moyen	Élevé	Important	Réunions de suivi
Évolution réglementaire	Faible	Moyen	Faible	Veille réglementaire
Résistance au changement	Moyen	Moyen	Modéré	Sensibilisation

16.2 Indicateurs de suivi

Les indicateurs suivants seront suivis :

- avancement du planning
- consommation budgétaire
- nombre de livrables validés
- nombre de risques ouverts
- nombre d'actions en retard
- taux de réalisation des actions
- 100 % des processus critiques identifiés et évalués
- 100 % des exigences réglementaires applicables recensées
- 100 % des actions critiques du plan de traitement affectées à un responsable

---

17. Livrables du projet

N°	Livrable
L1	Définition du périmètre
L2	Analyse des enjeux
L3	Exigences juridiques
L4	Gouvernance du SMSI
L5	Analyse des risques
L6	Politique de Sécurité (PSSI)
L7	PCA
L8	Plan d'actions
L9	Architecture cible
L10	Rapport d'audit interne
L11	Dossier de certification

---

18. Validation du document

Approbation

Le présent document entre en vigueur après validation par les responsables suivants.

Fonction	Nom	Signature	Date
Direction Générale	Antoine Verger	AV	30/03/2026
DSI	Mme Berthion	B	30/03/2026
Consultant cybersécurité	Quentin Berengolc	QB	30/03/2026

---

19. Conclusion

Le présent plan projet constitue la feuille de route de BioMarket pour la préparation de son Système de Management de la Sécurité de l'Information. Il formalise le périmètre de certification, les enjeux, les exigences réglementaires, la gouvernance, le planning et les ressources nécessaires à la réussite du projet.

Ce document servira de référence tout au long de la démarche de mise en conformité et sera mis à jour en fonction de l'avancement du projet et des décisions prises par le Comité de Pilotage.